

NETWORK SECURITY

Securing Networks

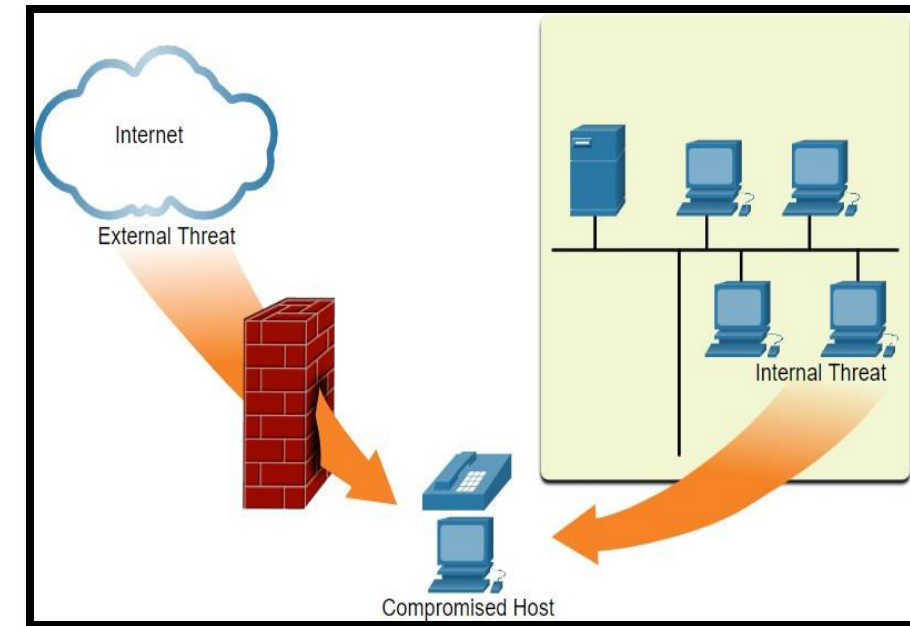
Current State of Cybersecurity

- Networks are routinely under attack.
- Cyber criminals now have the expertise and tools necessary to take down critical infrastructure and systems.
- Their tools and techniques continue to evolve.
- Network security breaches can disrupt e-commerce, cause the loss of business data, threaten people's privacy, and compromise the integrity of information.
- Maintaining a secure network ensures the safety of network users and protects commercial interests.

Security Terms	Description
Assets	An asset is anything of value to the organization. It includes people, equipment, resources, and data.
Vulnerability	A vulnerability is a weakness in a system, or its design, that could be exploited by a threat.
Threat	A threat is a potential danger to a company's assets, data, or network functionality.
Exploit	An exploit is a mechanism that takes advantage of a vulnerability.
Mitigation	Mitigation is the counter-measure that reduces the likelihood or severity of a potential threat or risk. Network security involves multiple mitigation techniques.
Risk	Risk is the likelihood of a threat to exploit the vulnerability of an asset, with the aim of negatively affecting an organization. Risk is measured using the probability of the occurrence of an event and its consequences.

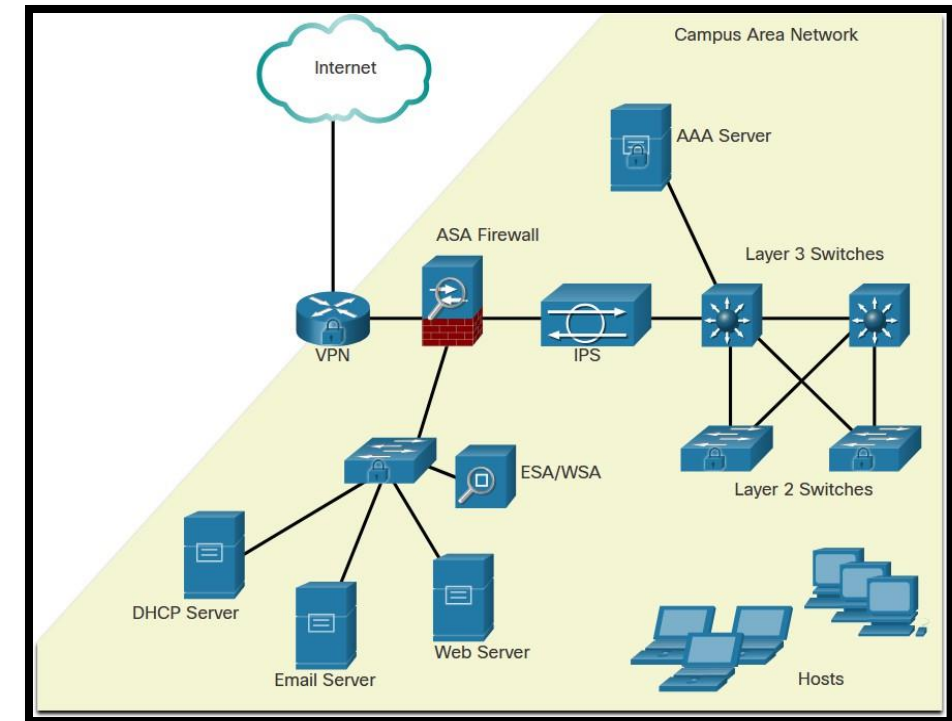
Vectors of Network Attacks

- An **attack vector** is a path by which a **threat actor** can gain access to a server, host, or network. Attack vectors **originate from inside or outside** the corporate network. For example, threat actors may target a network through the internet, to disrupt network operations and create a denial of service (DoS) attack.
- Internal threats have the potential to cause greater damage than external threats because internal users have direct access to the building and its infrastructure devices.
 - Employees may also have knowledge of the corporate network, its resources, and its confidential data.
- Network security professionals must **implement tools and apply techniques** for mitigating both external and internal threats.



Network Topology Overview: Campus Area Networks

- Campus Area Networks consists of interconnected LANs within a limited geographic area.
- Network professionals must implement various network security techniques to protect the organization's assets from outside and inside threats.
- Connections to untrusted networks must be checked in-depth by multiple layers of defense before reaching enterprise resources.
- This is known as **defense-in-depth**.

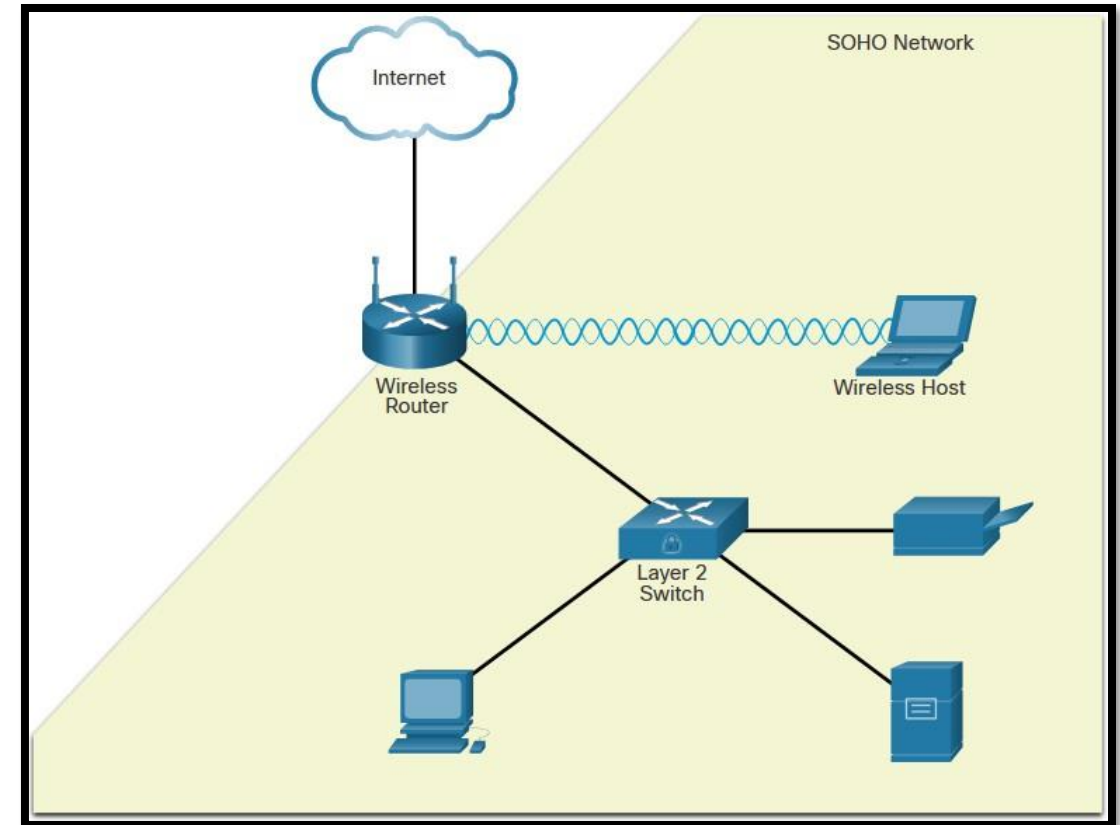


Network Topology Overview: Campus Area Networks (Contd.)

Term	Definition
VPN	The Cisco ISR is secured. It protects data in motion that is flowing from the CAN to the outside world by establishing Virtual Private Networks (VPNs). VPNs ensure data confidentiality and integrity from authenticated sources.
ASA Firewall	A Cisco Adaptive Security Appliance (ASA) firewall performs stateful packet filtering to filter return traffic from the outside network into the campus network.
IPS	A Cisco Intrusion Prevention System (IPS) device continuously monitors incoming and outgoing network traffic for malicious activity. It logs information about the activity and attempts to block and report it .
Layer 3 Switches	These distribution layer switches are secured and provide secure redundant trunk connections to the Layer 2 switches . Several different security features can be implemented, such as ACLs .
Layer 2 Switches	These access layer switches are secured and connect user-facing ports to the network. Several different security features can be implemented, such as port security .
ESA/WSA	A Cisco Email Security Appliance (ESA) and Web Security Appliance (WSA) provide advanced threat defense, application visibility and control, reporting , and secure mobility to secure and control email and web traffic .
AAA Server	An authentication, authorization, and accounting (AAA) server authenticates users, authorizes what they are allowed to do, and tracks what they are doing .
Hosts	End points are secured using various features including antivirus and antimalware software .

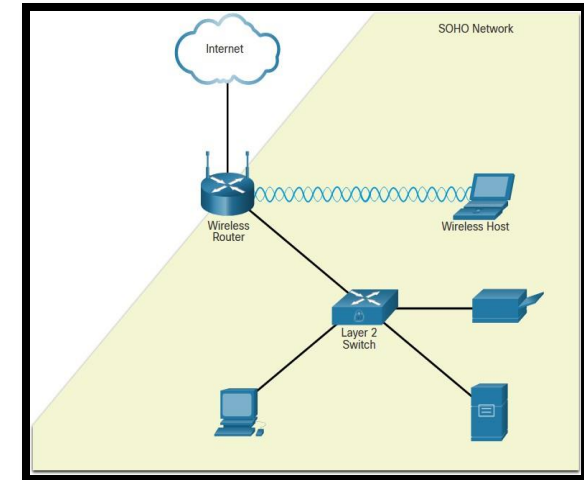
Network Topology Overview: Small Office and Home Office Networks

- Home and SOHO networks are typically protected using a **consumer grade router**.
- These routers provide basic security feature that adequately protect inside assets from outside attackers.



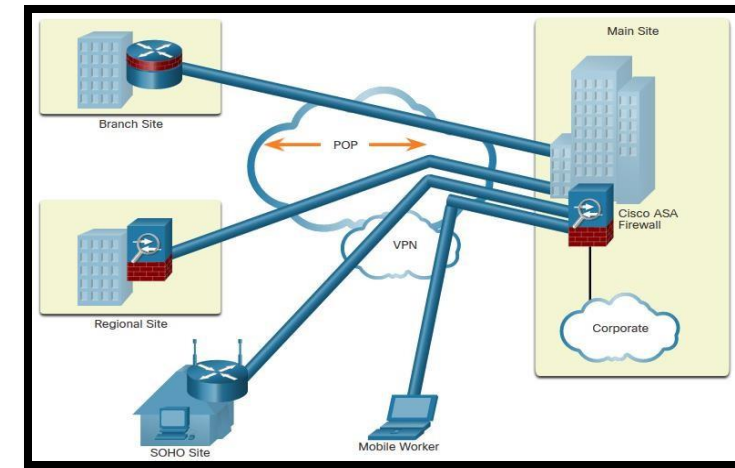
Network Topology Overview: Small Office and Home Office Networks (Cont.d)

- The figure displays a sample SOHO that uses a **consumer-grade wireless router** to secure it. A consumer-grade wireless router provides **integrated firewall features** and **secure wireless connections**.
- The **Layer 2 Switch** is an **access layer switch** that is hardened with various security measures. It **connects user-facing ports** that **use port security** to the SOHO network.
- **Wireless hosts** connect to the wireless network using **Wireless Protected Access 2 (WPA2) data encryption** technology.
- **Hosts** typically **have antivirus and antimalware software** installed.
- Combined, these security measures provide **comprehensive defense at different layers of the network**.



Network Topology Overview: Wide Area Networks

- Wide Area Networks (**WANs**) span a wide geographical area, often over the public internet. Organizations must **ensure secure transport for the data** in motion as it travels between sites over the public network. Network security professionals **must use secure devices** on the **edge of the network**.
- In the figure, the main site is protected by an **Adaptive Security Appliance (ASA)** cisco ASA Firewall, which provides **stateful firewall features** and **establishes secure Virtual Private Network (VPN) tunnels** to various destinations.



Network Topology Overview: Data Center Networks

- Data center networks are typically housed in an off-site facility to store sensitive data. These sites are connected to corporate sites using VPN technology with ASA devices and integrated data center switches.
- Because they store such vast quantities of sensitive, business-critical information, physical security is critical to their operation.
- Physical security not only protects access to the facility but also protects people and equipment.
 - For example, fire alarms, sprinklers, seismically-braced server racks, redundant heating, ventilation, and air conditioning (HVAC), and UPS systems are in place to protect people, equipment, and data.

Network Topology Overview: Data Center Networks

Data center physical security can be divided into two areas:

- **Outside perimeter security** - This can include on-premise security officers, fences, gates, continuous video surveillance, and security breach alarms.
- **Inside perimeter security** - This can include continuous video surveillance, electronic motion detectors, security traps, and biometric access and exit sensors.

Network Topology Overview: Virtualization

- **Virtualization** separates the operating system from the hardware.
 - Data centers are increasingly using virtual machines (VM) to provide server services to their clients.
 - This allows for **multiple operating systems** to **exist on a single hardware platform**.
 - VMs allow to run multiple virtual environments from a single machine, helping **reduce** physical infrastructure footprint, electricity bill, maintenance and management costs.

Network Topology Overview: Cloud Networks and Virtualization (Cont.d)

VMs are prone to specific targeted attacks:

- **Hyperjacking** - An attacker could hijack a VM hypervisor (VM controlling software) and then use it as a launch point to attack other devices on the data center network.
- **Instant On Activation** - When a VM that has not been used for a period of time is brought online, it may have outdated security policies that deviate from the baseline security and can introduce security vulnerabilities.
- **Antivirus Storms** - This happens when all VMs attempt to download antivirus data files at the same time.

Network Topology Overview: The Evolving Network Border

- Today, **consumer endpoints**, such as iPhones, smartphones, tablets, and thousands of other devices, are becoming powerful substitutes for, or complements to, the traditional PC. More and more people are using these devices to access enterprise information. This trend is known as **Bring Your Own Device (BYOD)**.
- To accommodate the BYOD trend, Cisco developed the **Borderless Network**. In a Borderless Network, access to resources can be initiated by users from many locations, on many types of endpoint devices, using various connectivity methods.
- To support this blurred network edge, Cisco devices support **Mobile Device Management (MDM) features**. MDM features secure, monitor, and manage mobile devices, including corporate-owned devices and employee-owned devices. **MDM-supported and managed devices** include not only handheld devices, such as smartphones and tablets, but also laptop and desktop computing devices.

Network Topology Overview: The Evolving Network Border (Cont.d)

- **Data Encryption** - **MDM features** can ensure that **only devices that support data encryption** and have it enabled can access the network and content.
- **PIN Enforcement** - Enforcing **a PIN lock** is the **first and most effective step** in preventing unauthorized access to a device.
- **Data Wipe** - **Lost or stolen devices** can be **remotely fully- or partially-wiped**, either by the user or by an administrator **via the MDM**.
- **Data Loss Prevention (DLP)** - DLP prevents authorized users from doing careless or malicious things with critical data.
- **Jailbreak/Root Detection** - **Jailbreaking** (on Apple iOS devices) and **rooting** (on Android devices) are a means to **bypass the management of a device**. **MDM features can detect such bypasses** and **immediately restrict a device's access to the network or assets**.

Common Network Attacks

- To mitigate attacks, it is useful to understand the types of attacks.
- Networks are susceptible to the following types of attacks:
 - Reconnaissance Attacks
 - Access Attacks
 - DoS Attacks

Common Network Attacks: Reconnaissance Attacks

- Reconnaissance is **information gathering**.
- Threat actors use reconnaissance (or recon) **attacks** to do **unauthorized discovery** and **mapping of systems, services, or vulnerabilities**. Recon attacks precede access attacks or **DoS attacks**.

Technique	Description
Perform an information query of a target	The threat actor is looking for initial information about a target . Various tools can be used, including the Google search, organizations website, whois , and more.
Initiate a ping sweep of the target network	The information query usually reveals the target's network address. The threat actor can now initiate a ping sweep to determine which IP addresses are active .
Initiate a port scan of active IP addresses	This is used to determine which ports or services are available . Examples of port scanners include Nmap, SuperScan, Angry IP Scanner, and NetScanTools .
Run vulnerability scanners	This is to query the identified ports to determine the type and version of the application and operating system that is running on the host . Examples of tools include Nipper, Core Impact, Nessus, SAINT, and Open VAS .
Run exploitation tools	The threat actor now attempts to discover vulnerable services that can be exploited. A variety of vulnerability exploitation tools exist including Metasploit, Core Impact, Sqlmap, Social Engineer Toolkit, and Netsparker .

Common Network Attacks:

Access Attacks

- **Access attacks** exploit known vulnerabilities in authentication services, FTP services, and web services. The purpose of these types of attacks is to gain entry to web accounts, confidential databases, and other sensitive information.
 - Threat actors use access attacks on network devices and computers to retrieve data, gain access, or to escalate access privileges to administrator status.
- **Password Attacks:** In a password attack, the threat actor attempts to discover critical system passwords using various methods.
 - Password attacks are very common and can be launched using a variety of password cracking tools.
- **Spoofing Attacks:** In spoofing attacks, the threat actor device attempts to pose as another device by falsifying data.
 - Common spoofing attacks include IP spoofing, MAC spoofing, and DHCP spoofing.

Common Network Attacks: Access Attacks

Other Access attacks include:

- Trust exploitations
- Port redirections
- Man-in-the-middle attacks
- Buffer overflow attacks

Common Network Attacks: Social Engineering Attacks

- Social engineering is an access attack that attempts to manipulate individuals into performing actions or divulging confidential information.
- Some social engineering techniques are performed in-person while others may use the telephone or internet.
- Social engineers often rely on people's willingness to be helpful. They also prey on people's weaknesses.

Common Network Attacks: Social Engineering Attacks

Social Engineering Attack	Description
Pretexting	A threat actor pretends to need personal or financial data to confirm the identity of the recipient .
Phishing	A threat actor sends fraudulent email which is disguised as being from a legitimate, trusted source to trick the recipient into installing malware on their device , or to share personal or financial information .
Spear phishing	A threat actor creates a targeted phishing attack tailored for a specific individual or organization.
Spam	Also known as junk mail , this is unsolicited email which often contains harmful links, malware, or deceptive content .
Something for Something	Sometimes called " Quid pro quo ", this is when a threat actor requests personal information from a party in exchange for something such as a gift.
Baiting	A threat actor leaves a malware infected flash drive in a public location . A victim finds the drive and unsuspectingly inserts it into their laptop , unintentionally installing malware.
Impersonation	This type of attack is where a threat actor pretends to be someone they are not to gain the trust of a victim .
Tailgating	This is where a threat actor quickly follows an authorized person into a secure location to gain access to a secure area .
Shoulder surfing	This is where a threat actor inconspicuously looks over someone's shoulder to steal their passwords or other information .
Dumpster diving	This is where a threat actor rummages through trash bins to discover confidential documents .

Common Network Attacks: Social Engineering Attacks (Contd.)

- The **Social Engineering Toolkit** (SET) was designed to help **white hat hackers** and other **network security professionals** create social engineering attacks to test their own networks.
- Enterprises must educate their users about the risks of social engineering, and develop strategies to validate identities over the phone, via email, or in person.
- The figure shows recommended practices that should be followed by all users.



Common Network Attacks: DoS and DDoS Attacks

- A Denial of Service (DoS) attack creates some sort of **interruption of network services** to users, devices, or applications. There are two major types of DoS attacks:
 - 1. Overwhelming Quantity of Traffic** - The threat actor sends an enormous quantity of data at a rate that the network, host, or application cannot handle. This causes transmission and response times to slow down. It can also crash a device or service.
 - 2. Maliciously Formatted Packets** - The threat actor sends a maliciously formatted packet to a host or application and the receiver is unable to handle it. This causes the receiving device to run very slowly or crash.
- **DoS attacks** are a major risk because they interrupt communication and cause significant loss of time and money. These attacks are relatively simple to conduct, even by an unskilled threat actor.
- A **Distributed DoS Attack** (DDoS) is similar to a DoS attack, but it originates from multiple, coordinated sources.

Defending Network

Information security deals with protecting information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction. The CIA Triad serves as a conceptual foundation for the field.

The CIA Triad consists of three components of information security:

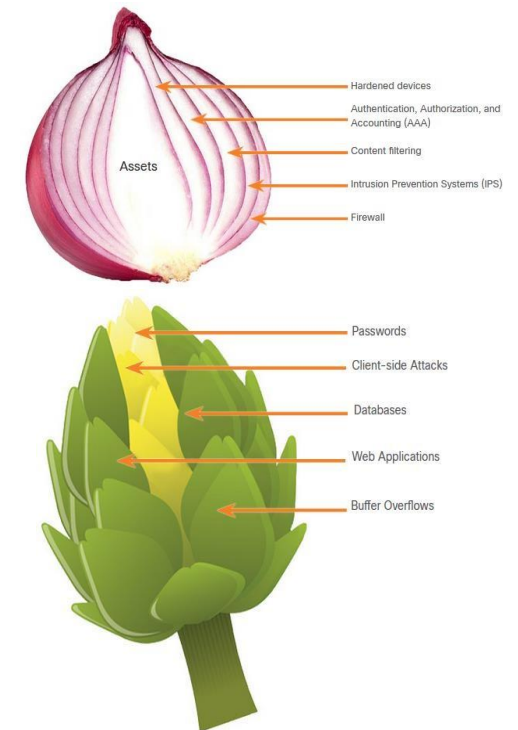
- **Confidentiality** - Only authorized individuals, entities, or processes can access sensitive information.
- **Integrity** - This refers to the protection of data from unauthorized alteration.
- **Availability** - Authorized users must have uninterrupted access to the network resources and data that they require.



The Security Onion and The Security Artichoke

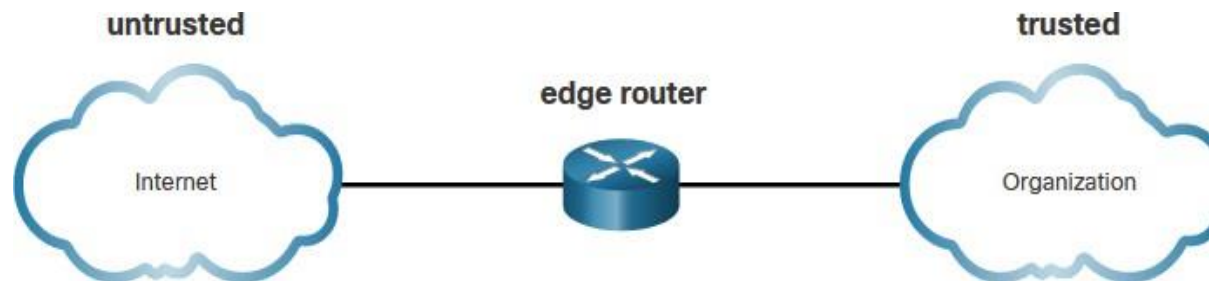
A common analogy used to describe a defense-in-depth approach is called "the security onion." A threat actor would have to peel away at a network's defenses layer by layer in a manner similar to peeling an onion. Only after penetrating each layer would the threat actor reach the target data or system.

The changing landscape of networking, such as the evolution of borderless networks, has changed this analogy to the "security artichoke", which benefits threat actors because they no longer have to peel away each layer. They only need to remove certain "artichoke leaves." The threat actor peels away the security armor along the perimeter to get to the "heart" of the enterprise.



Secure the Network Infrastructure

- Securing the network infrastructure is critical to overall network security. The network infrastructure includes routers, switches, servers, endpoints, and other devices. Routers are a primary target for attacks because these devices direct traffic into, out of, and between networks.
- The edge router shown in the figure is the last router between the internal network and an untrusted network, such as the internet. All an organization's internet traffic goes through an edge router, which often functions as the first and last line of defense for a network.



Edge Router Security Approach

- **Single Router** - A single router connects the protected network or internal local area network (LAN) to the internet. All security policies are configured on this device.
- **Defense-in-Depth** - This uses multiple layers of security prior to traffic entering the protected LAN. There are **three primary layers of defense**: the **edge router**, the **firewall**, and an **internal router** that connects to the protected LAN.
- **DMZ** - The DMZ can be **used for servers** that must be accessible from the internet or another external network. The DMZ can be set up between two routers, with an internal router connecting to the protected network and an external-router connecting to the unprotected network.

